

SHIELD Framework: Privacy Without Friction for Secure AI under Bangladesh PDPA

Robi Data Privacy Avengers Concept Paper | TeamNullX | New Telecom Ltd Case Study

1. Deconstruction of the Problem

New Telecom Ltd aims to scale six AI services (support assistants, fraud detection, churn prediction, marketing recommendations, network optimisation, and document processing) under Bangladesh's Personal Data Protection Act, 2026, which requires lawful processing, minimisation, accountability, third-party control, individual rights, and a ban on tracking, profiling, or targeting children under eighteen. Cybersecurity has matured, but privacy work remains fragmented across developers, cloud, AI vendors, analytics, and marketing. Leadership still cannot clearly answer where personal data lives, which apps and AI systems use it, which vendors receive it, what leaves Bangladesh, whether decisions are explainable, who is accountable, or how to prove PDPA compliance in an audit. Generative AI adds prompt injection, training leakage, biased or opaque outcomes, and cross-border retention risk. The real task is not more tools, but a joined-up way to adopt AI safely while keeping protection almost invisible to customers and offering fast human help when something goes wrong. We call this privacy without friction.

2. Key Privacy Challenges

Privacy risks include over-collection, personal data trapped in prompts, embeddings, logs and vector stores, and weaker safeguards for employee data. Security risks include prompt injection, model inversion, shadow public GenAI, and vendor exfiltration. Ethical risks include unfair fraud or churn outcomes and adult-registered SIMs used by children. Compliance risks include weak processing records, incomplete vendor and cross-border evidence, and accidental breach of the children's ban. Customers feel this as wrongful blocks, AI chat loops, consent fatigue, app-only privacy tools, slow data requests, and vague breach messages that scammers can copy. Rights on paper will not earn trust if everyday experience feels unfair or hard to use.

3. Proposed Approach

SHIELD is our proposed target model. We place AI in an isolated, highly available zone under Zero Trust (ZTNA, microsegmentation, next-generation firewall), with mutual TLS in the pipeline, fail-closed recovery for critical AI, and a documented kill switch. Access is purpose-bound (attribute-based controls, just-in-time privilege, and FIDO2-style MFA for staff rather than SMS-only OTP for privileged roles), with human review above impact thresholds. Data is encrypted in transit and at rest, with field protection for sensitive identifiers, tokenisation, KMS/HSM keys, residency tagging, automated discovery, an app-to-data inventory, and auto-deletion for prompts, embeddings, logs, training sets and vector databases, plus retrain-on-erasure. Non-production uses masked or synthetic data only.

Support AI runs as a hardened retrieval assistant: Bangladesh-aware redaction of NID and phone numbers, behaviour and pattern checks against prompt attacks, anomaly and rate guards, then either retrieve or block with human handoff. Fraud and churn models use a written differential-privacy budget (working target around $\epsilon = 1.0$), SHAP for specialists, plain reason codes for customers, decision logs, bias tests, model cards, drift monitoring and rollback, with a privacy-and-AI impact gate before go-live. If age is uncertain we treat the user as a child: no profiling, and under-eighteens stay out of marketing and churn behavioural models, with parent guidance and periodic audits.

For customers, adverse decisions carry reason codes; fraud blocks prefer step-up checks or fast review with temporary release and a proactive SMS; appeals are available; bots disclose themselves and hand off after failed turns; channels include Bangla, English and mixed language, plus dashboard, USSD, IVR, SMS and retail so feature-phone users are included. Consent is granular, without dark patterns or service penalties for opting out; data requests have SLAs and status tracking; complaints can escalate and wrongs are remediated. We track CSAT, trust, false-positive rate and handling times. Vendors are tiered under contracts that ban training on our data, require exit deletion, monitor egress, register cross-border transfers and prefer in-country processing. An independent data protection officer can stop high-risk launches, supported by an AI and Privacy Council and an AI-aware breach playbook within PDPA timelines. We reject blockchain for personal data, MAC-based login, keyword-only filters, and public GenAI with live personal data.

4. Expected Impact

Customers get clearer control, safer AI chats, fairer fraud handling, stronger child protection and channels beyond a smartphone app. The organisation can answer the eight leadership questions, reduce breach and regulatory risk, reuse controls across all six AI uses, and stand ready for audit. Responsible AI becomes everyday practice: privacy by design that supports innovation and loyalty rather than a late veto.

5. Applicability in Bangladesh

SHIELD fits PDPA 2026 and local telecom reality: NID and +880 phone formats, Bangla-first inclusive access, adult-registered SIMs used by minors, in-country processing by default, and registers regulators can inspect. It supports Smart Bangladesh digital trust and can transfer to banks, fintech and public services facing the same AI and privacy tension.

In short, SHIELD helps New Telecom adopt AI under PDPA while keeping privacy practical, fair and close to the customer.

Reference

Technical demos, architecture notes and supporting materials: <https://github.com/rahatsahriarafi/SHIELD-Framework>